

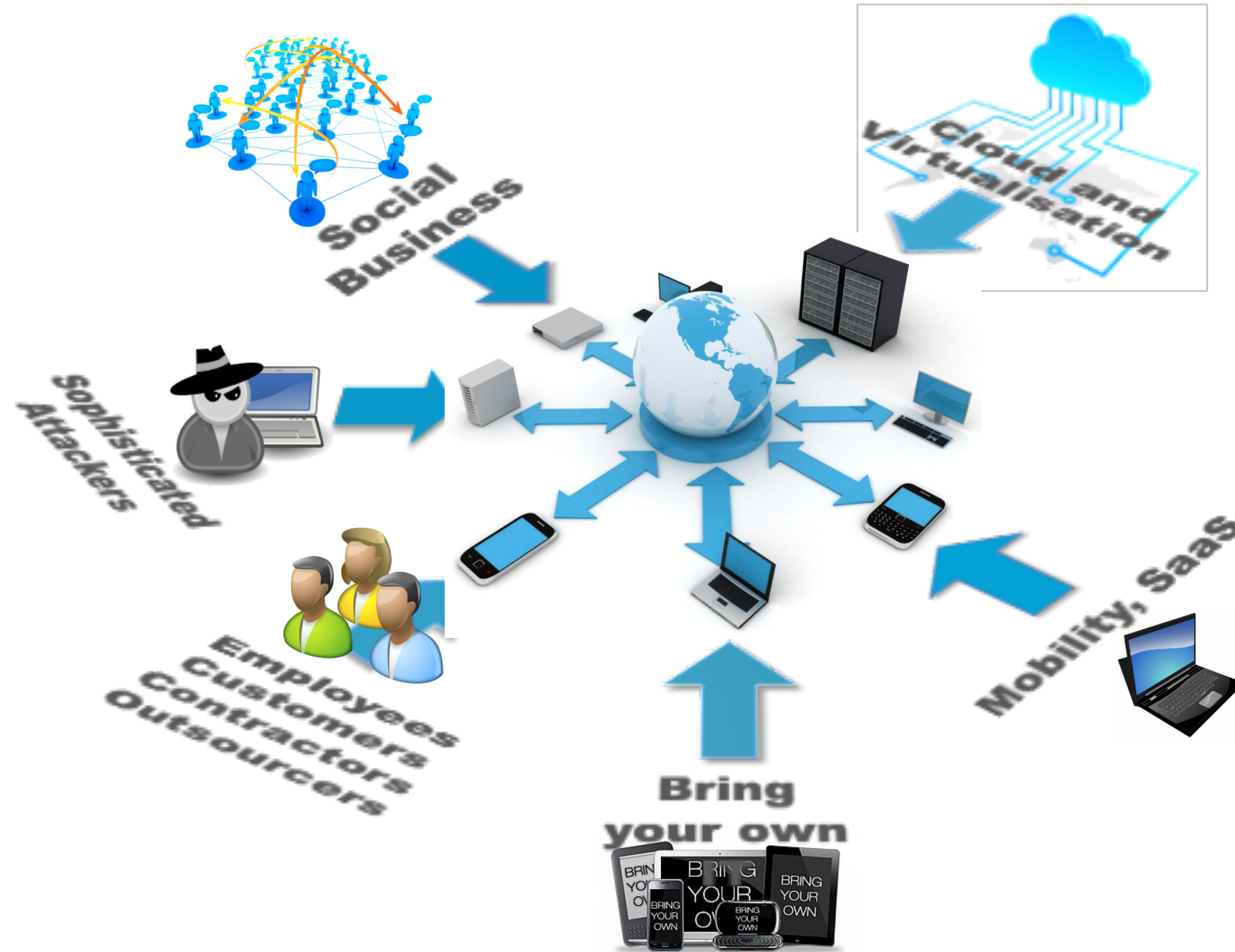
Detecting and Preventing Data Exfiltration

Dr. Ramokapane



Bristol Cyber Security Group

The Threatscape



ATTACK SOPHISTICATION

TOOLKIT DEVELOPERS

MALWARE DEVELOPERS

VULNERABILITY DISCOVERERS

SHIFT IN MOTIVES

INDUSTRIAL ESPIONAGE (APTs)

NATIONAL SECURITY, ECONOMIC
ESPIONAGE (NATION STATES, APTs)

STUXNET, FLAME, AURORA, DUQU

MONETARY GAIN (ORGANISED CRIME)

ZEUS, ZEROACCESS, BLACKHOLE

PARTIAL TRUST MODEL

DIVERSITY OF NETWORK USERS

HETEROGENEOUS IT INFRASTRUCTURE

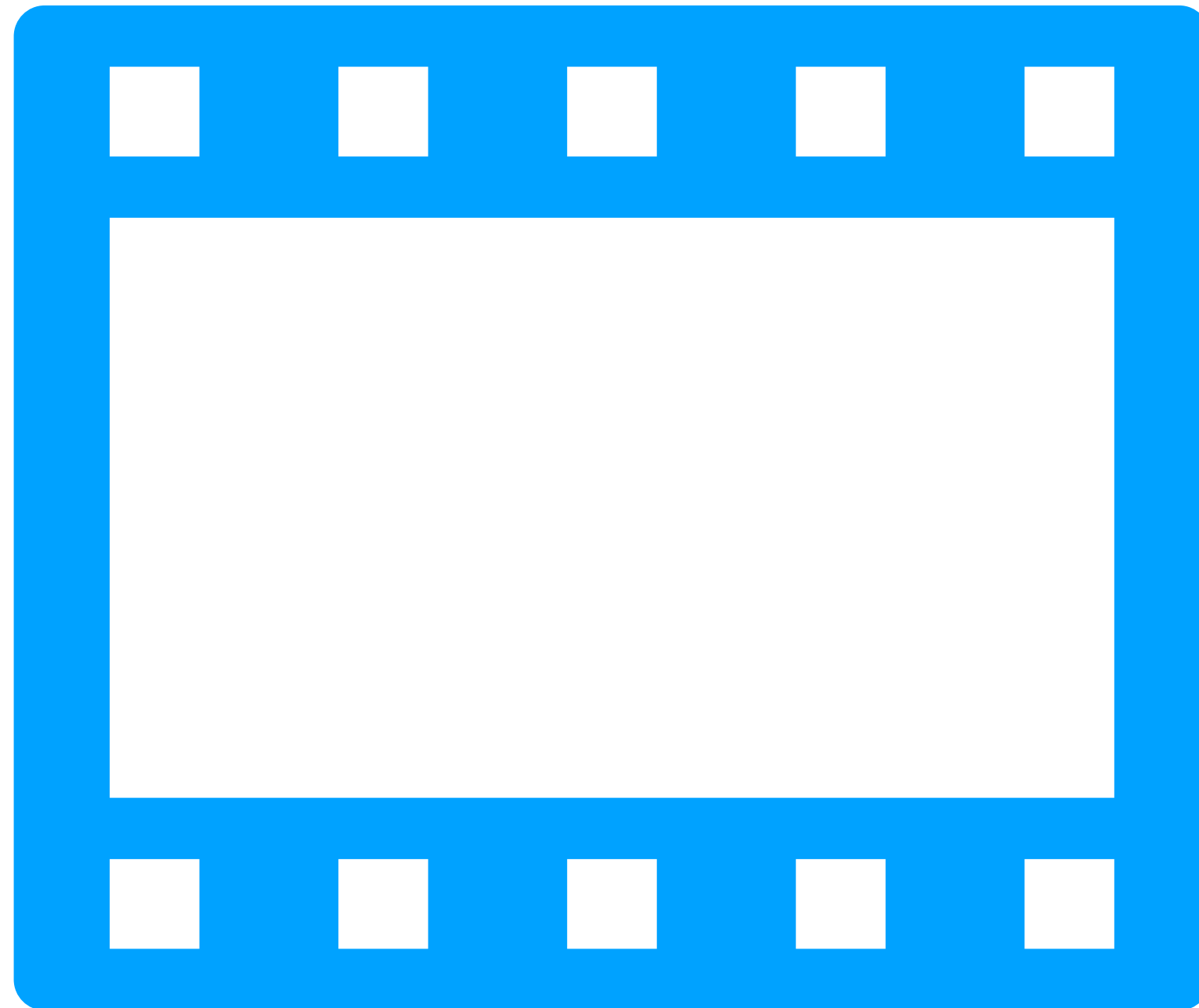
NEW ATTACK VECTORS

BRING YOUR OWN IT

NEW TECHNOLOGIES

NEW BUSINESS MODELS

Anatomy of an Attack



There is no Perfect Cyber Security!

Determined attackers will gain access

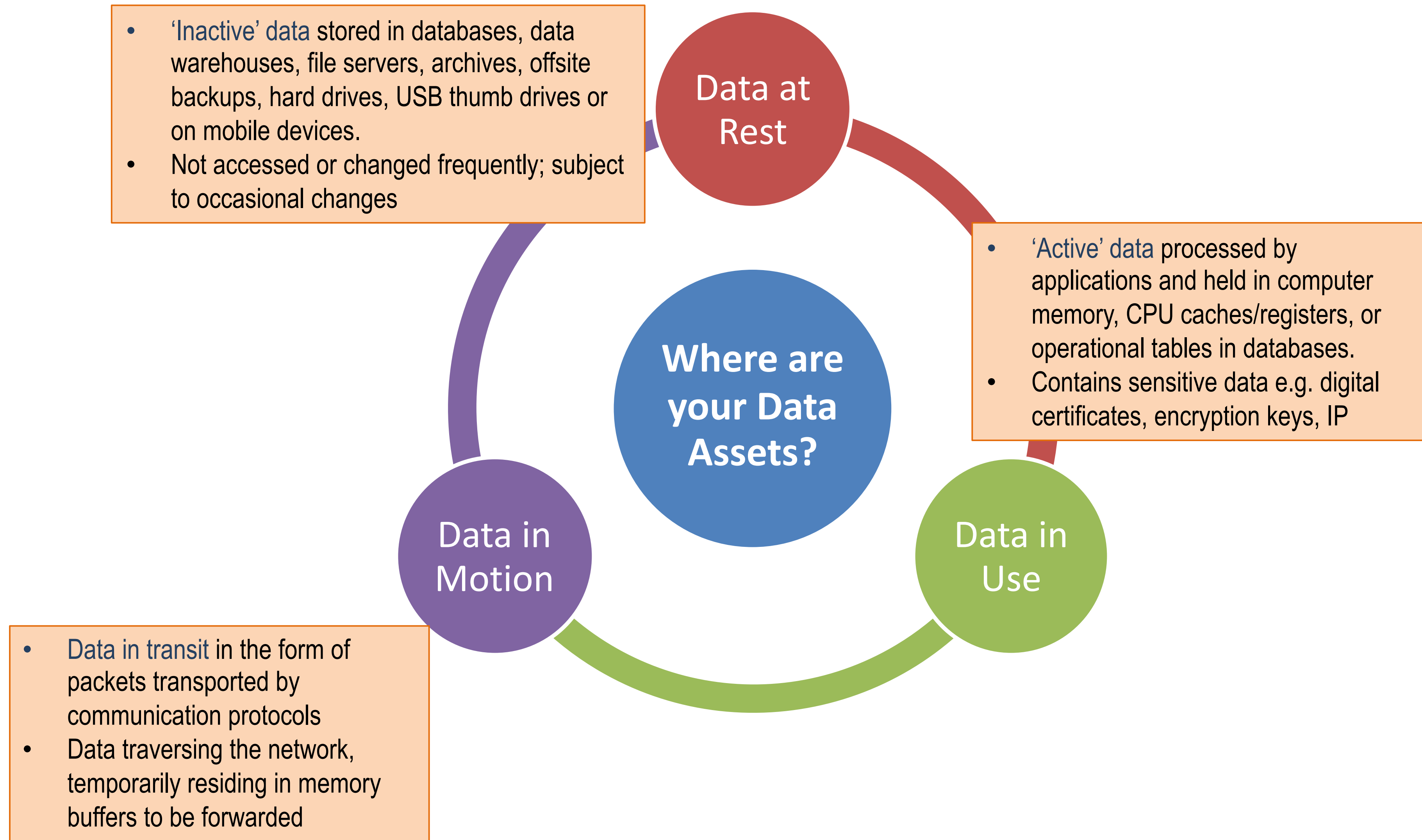
Thinking Beyond Breaches

Assuming that at some point a breach in the security measures will take place
...

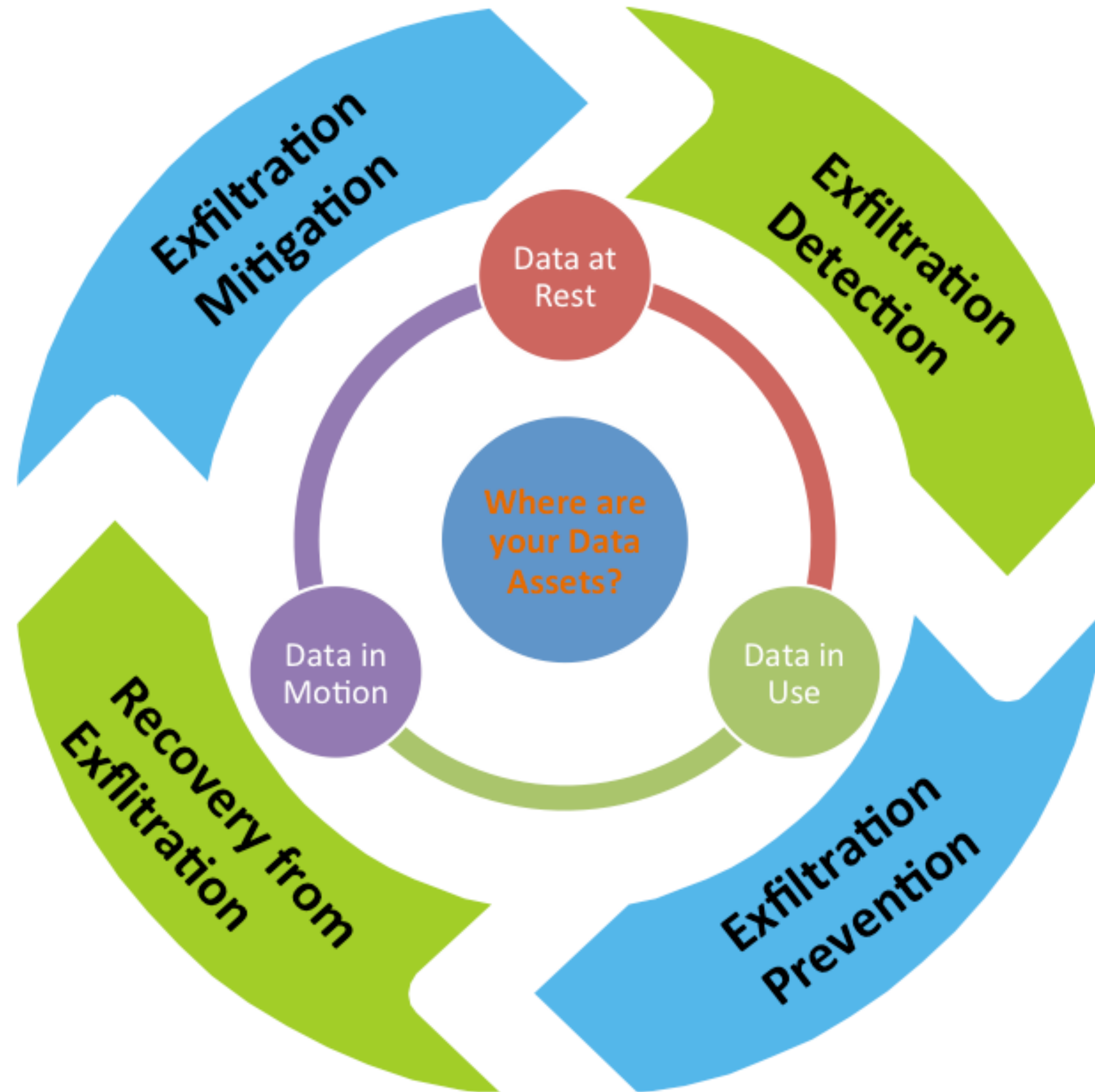
... what mechanisms can enable us to detect, stop or at least disrupt data exfiltration from the organisation's system following such a breach?

Resilience!

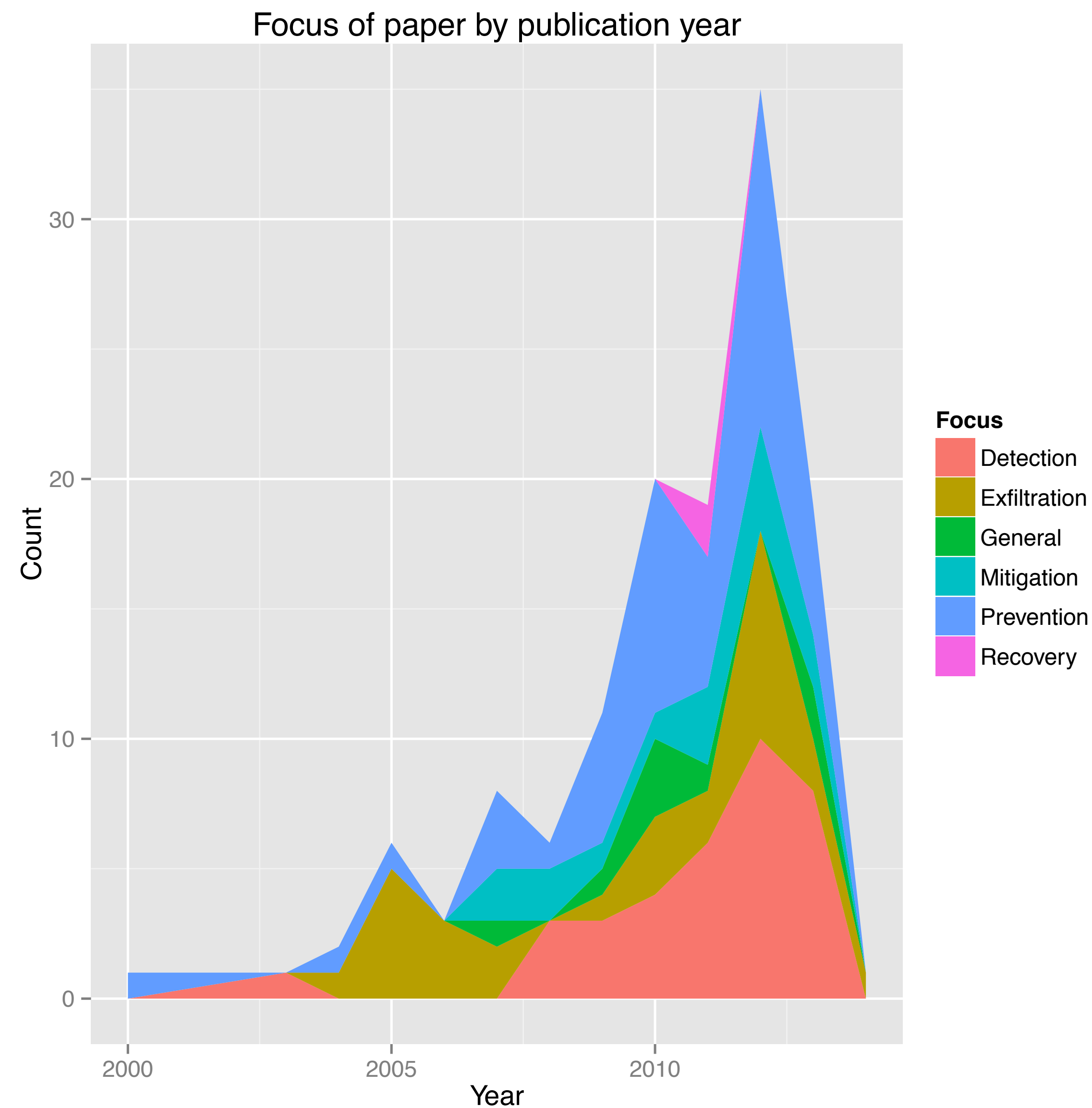
Exfiltration Attempts Target Diverse Data Assets



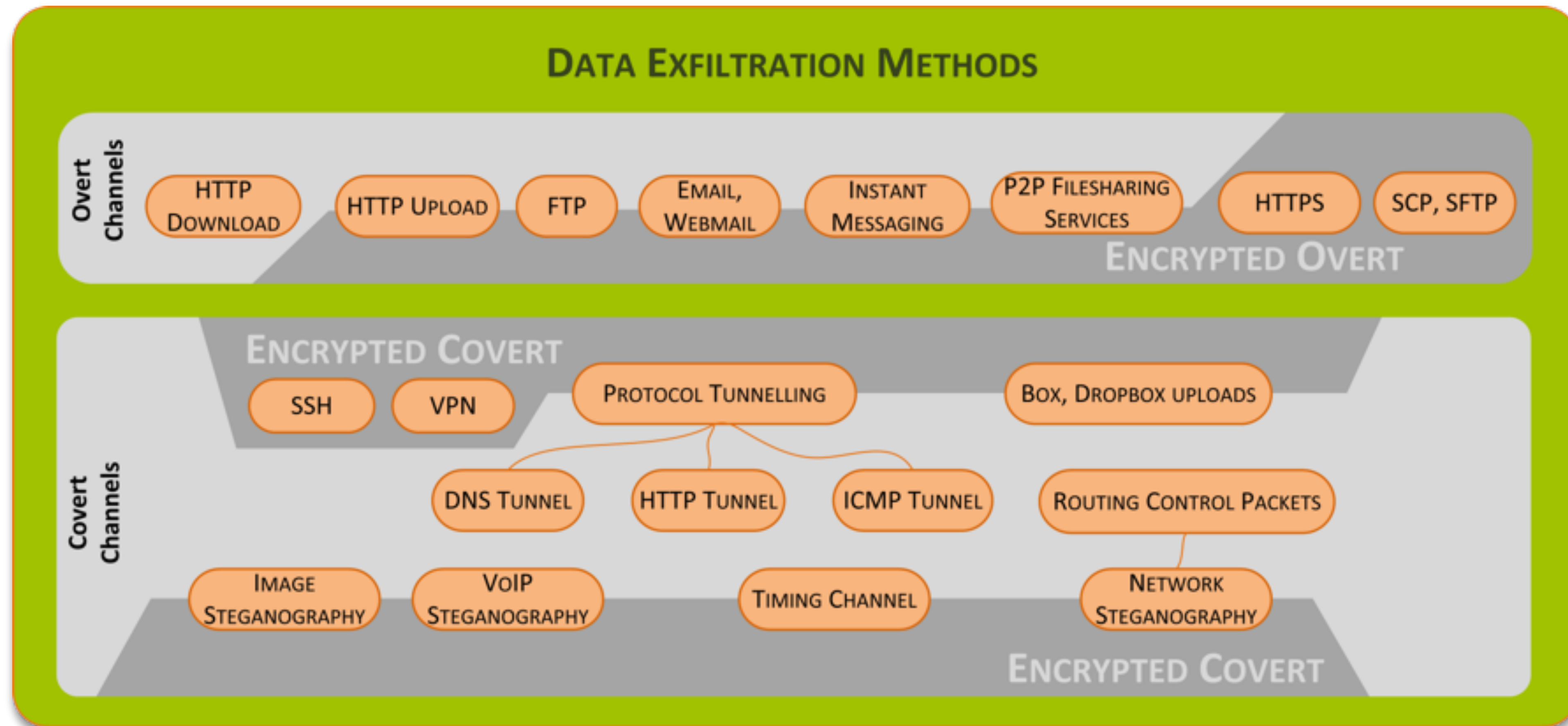
Holistic Approach to Countermeasures is Essential



Recovery is Equally Important!

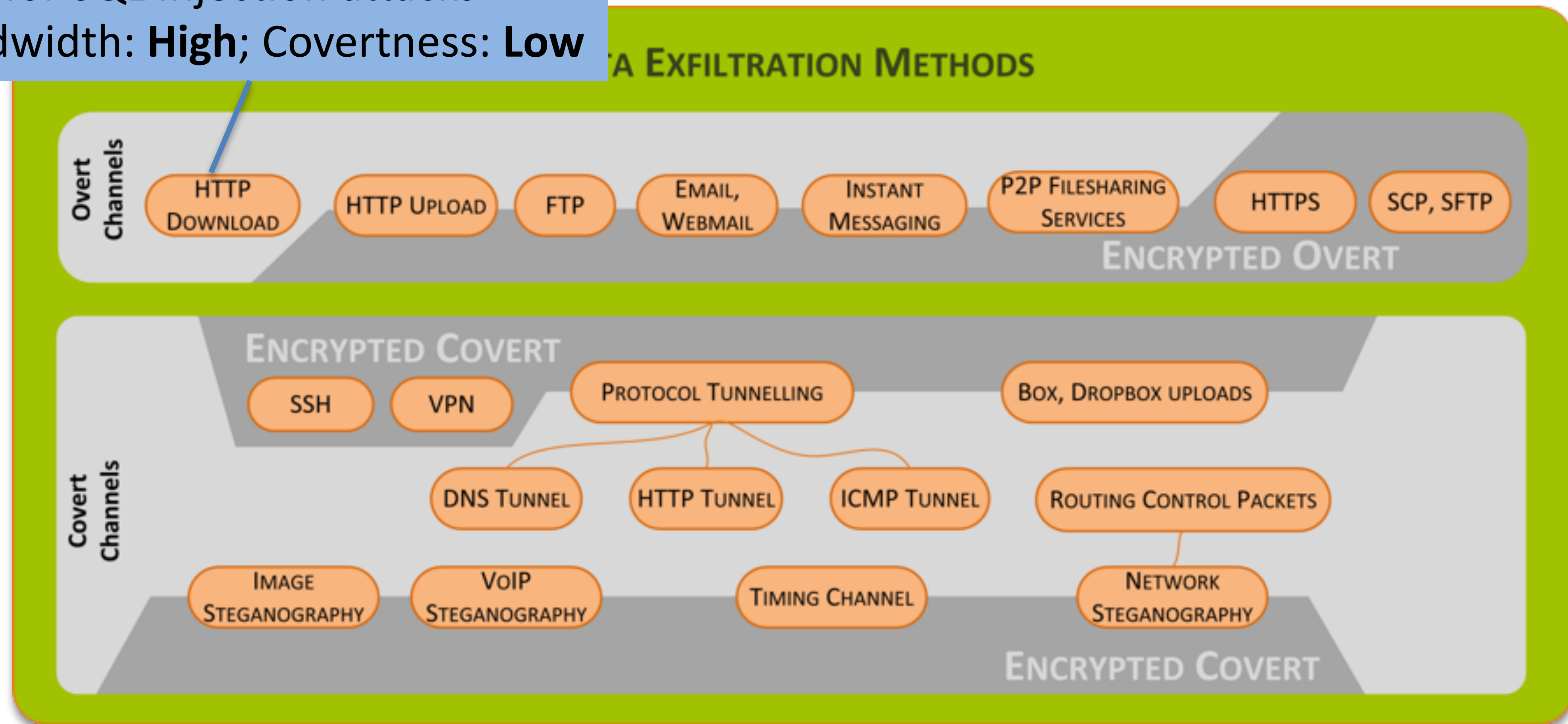


Typical Exfiltration Modes

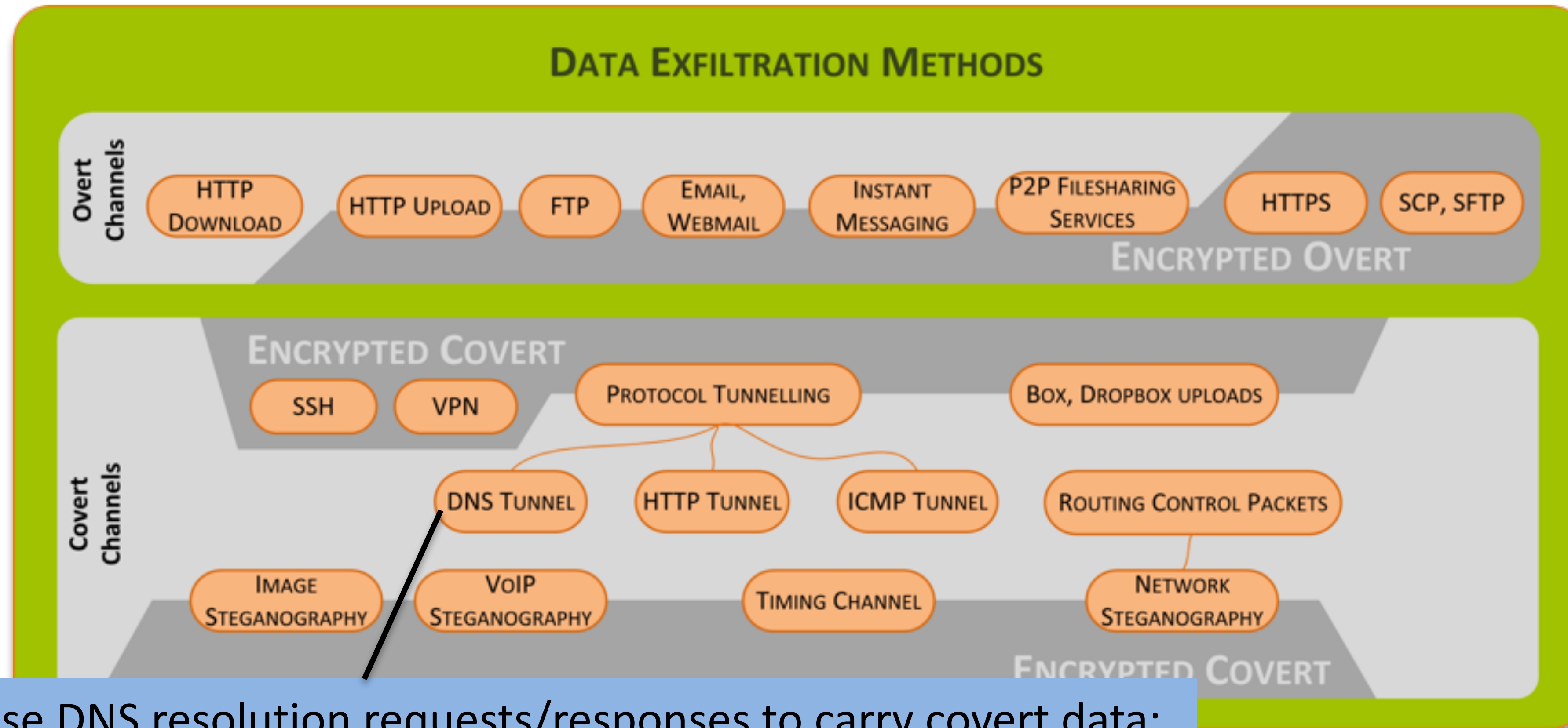


Typical Exfiltration Modes

E.g., for SQL Injection attacks
Bandwidth: **High**; Covertness: **Low**

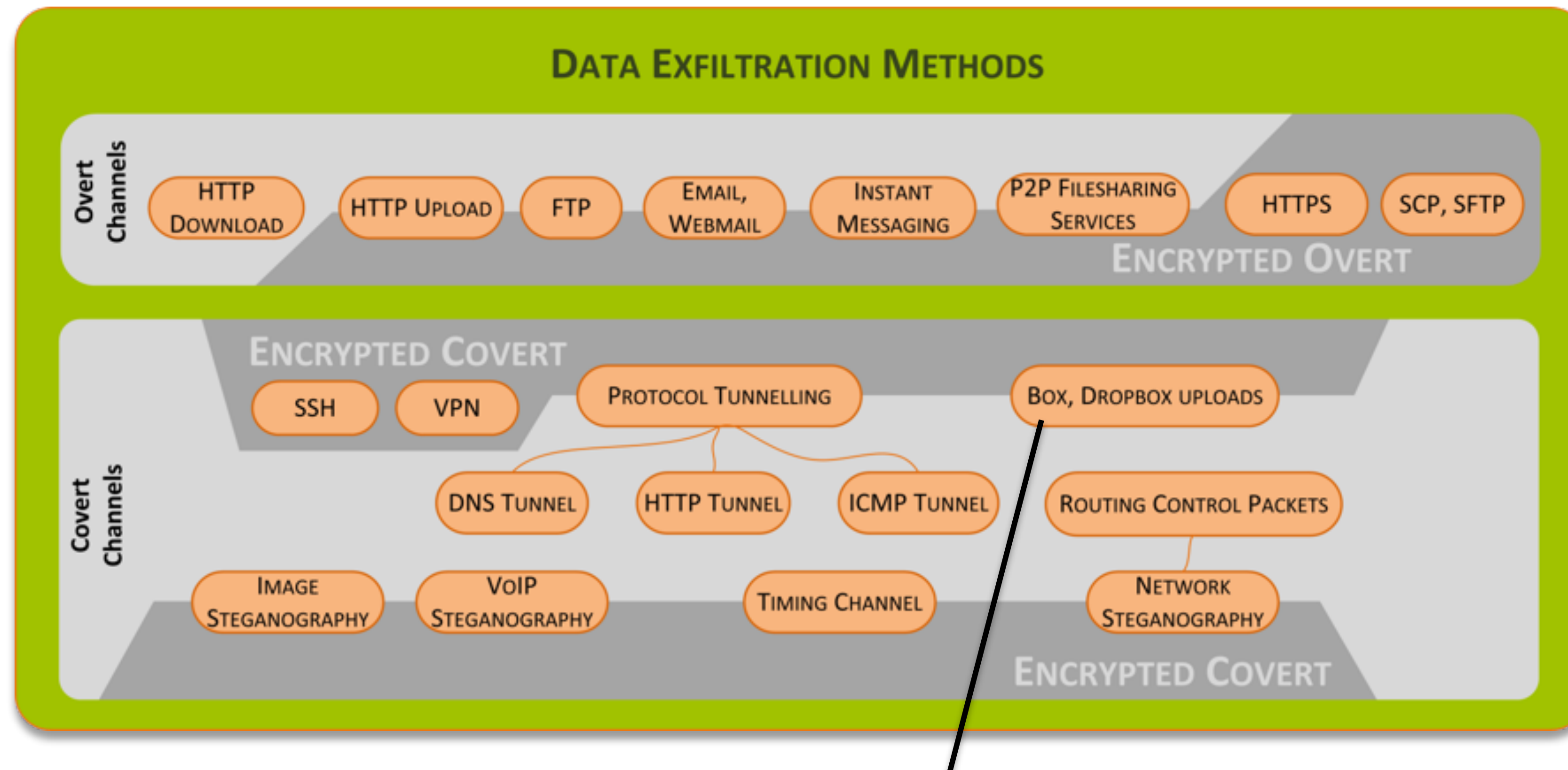


Typical Exfiltration Modes



Use DNS resolution requests/responses to carry covert data;
Unlikely to be blocked by perimeter firewall
Bandwidth: **Medium/Low (~110 KB/s)**; Coverttness: **High**
Already in the wild: Feederbot, Moto, Squeeza, sqlmap

Typical Exfiltration Modes



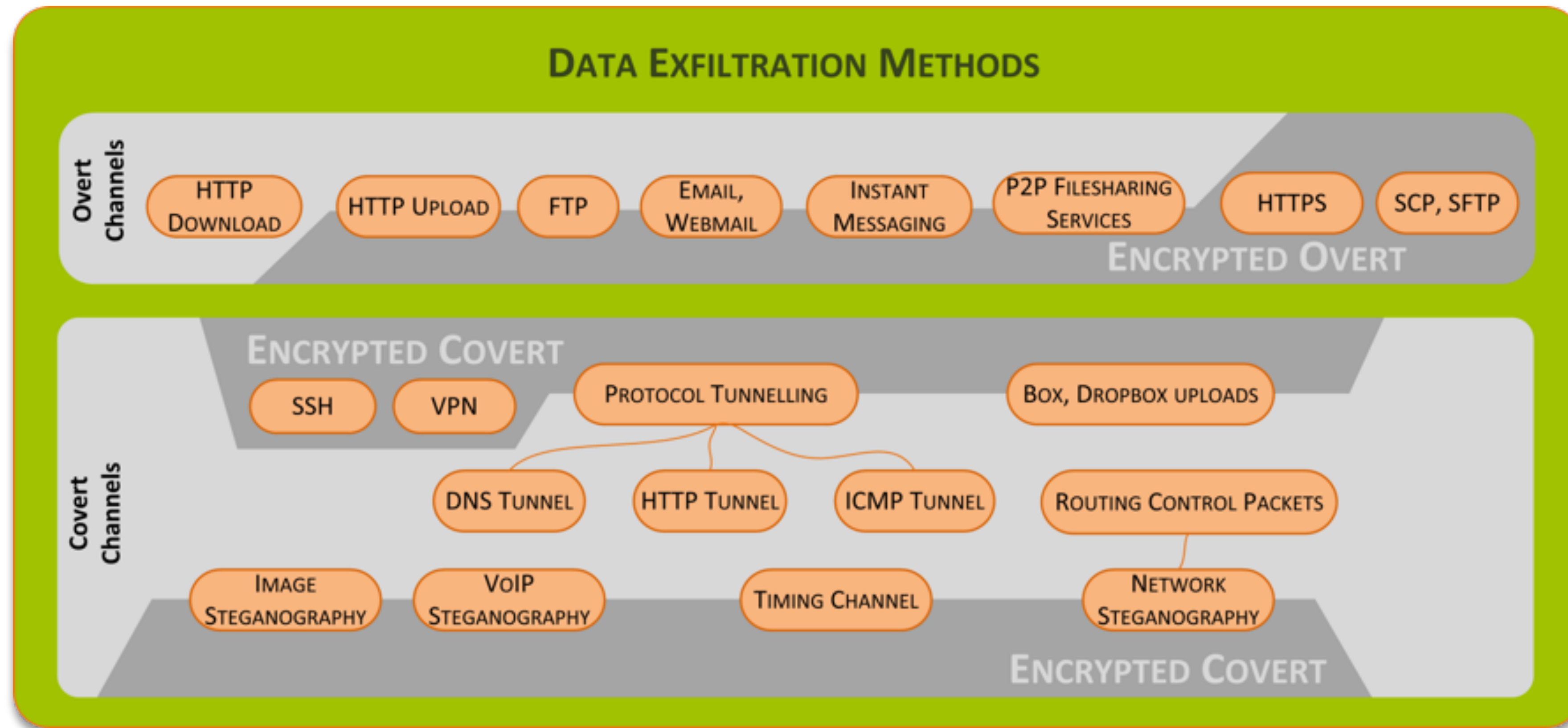
Blends with normal traffic

Trusted sites for C2 control point and as a collection point for extracted files

Malware implant receives C2 instructions over same channel

Bandwidth: **High**; Covertness: **High/Medium**

Typical Exfiltration Modes



In-band vs.
Out-of-band

Use of Trusted
Sites

Attackers also think
of Resilience!

How to Detect Exfiltration Attempts?

Known channel inspection

Monitor network traffic at a boundary

Detect unusual access patterns at the host

E.g., ratio between request and response sizes per destination,
identifying outliers as suspect

E.g., Byte entropy to detect usage of covert, encrypted, channels

Model information flow to detect 'leaker' components

Watermark data (to help the above and to trace leaks)

Prevention and Mitigation Measures

Actuated detection systems: give network monitors the ability to mask data, or else prevent outgoing traffic reaching its destination

‘Self-protect’ data

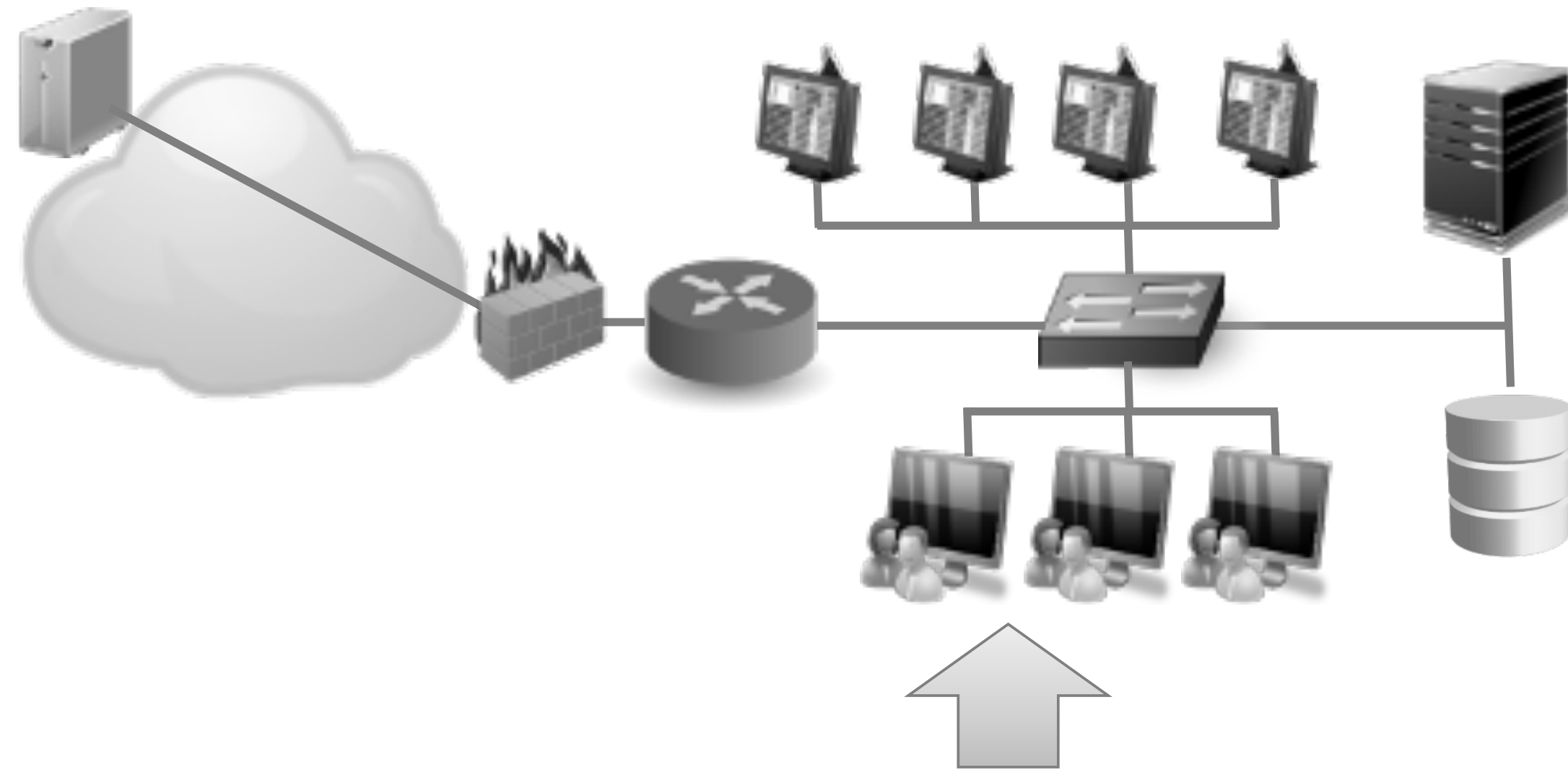
- DRM-like systems using encryption

- Use intelligent databases or file systems to detect malicious queries and prevent access (E.g., Cyclical hashing of documents; hashes used by a Data Leakage Prevention system to detect document exfiltration)

Security policy assistance tools

Low level snooping defences

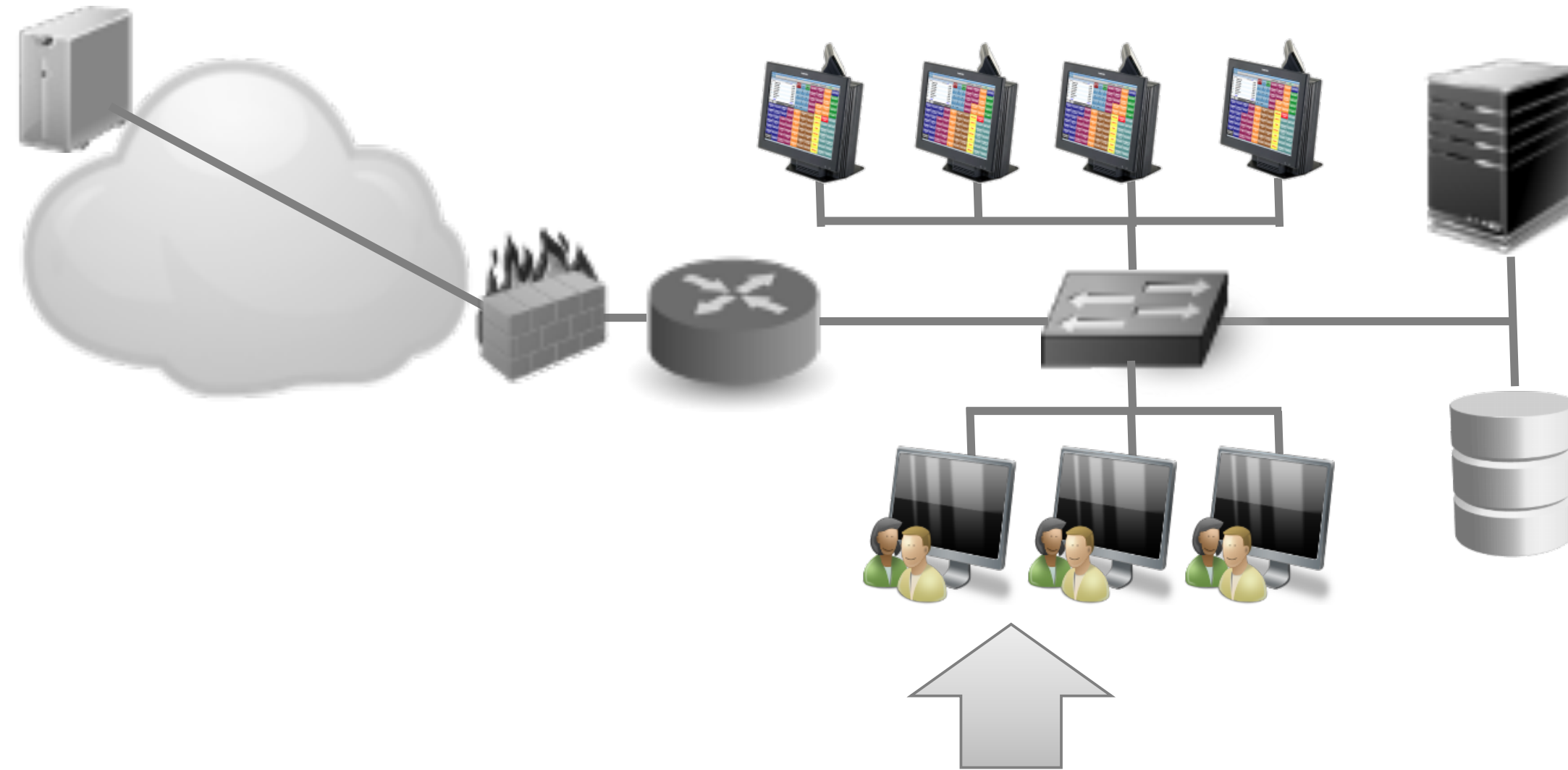
Controls: Data at Rest



① Sensitive Data (at Rest) Discovery

- ✓ Deploy hard-drive encryption on hosts
- ✓ Discover your Google Dorks
 - `site:yourwebsite.com pdf`
 - `site:yourwebsite.com "internal use only"`
 - `site:yourwebsite.com private`
 - `site:yourwebsite.com confidential`
 - `site:yourwebsite.com "log in"`
 - `Site:yourwebsite.com error`
- ✓ Assess data to identify sensitive information
- ✓ Deploy automated tools for periodic scans of servers and mobile devices

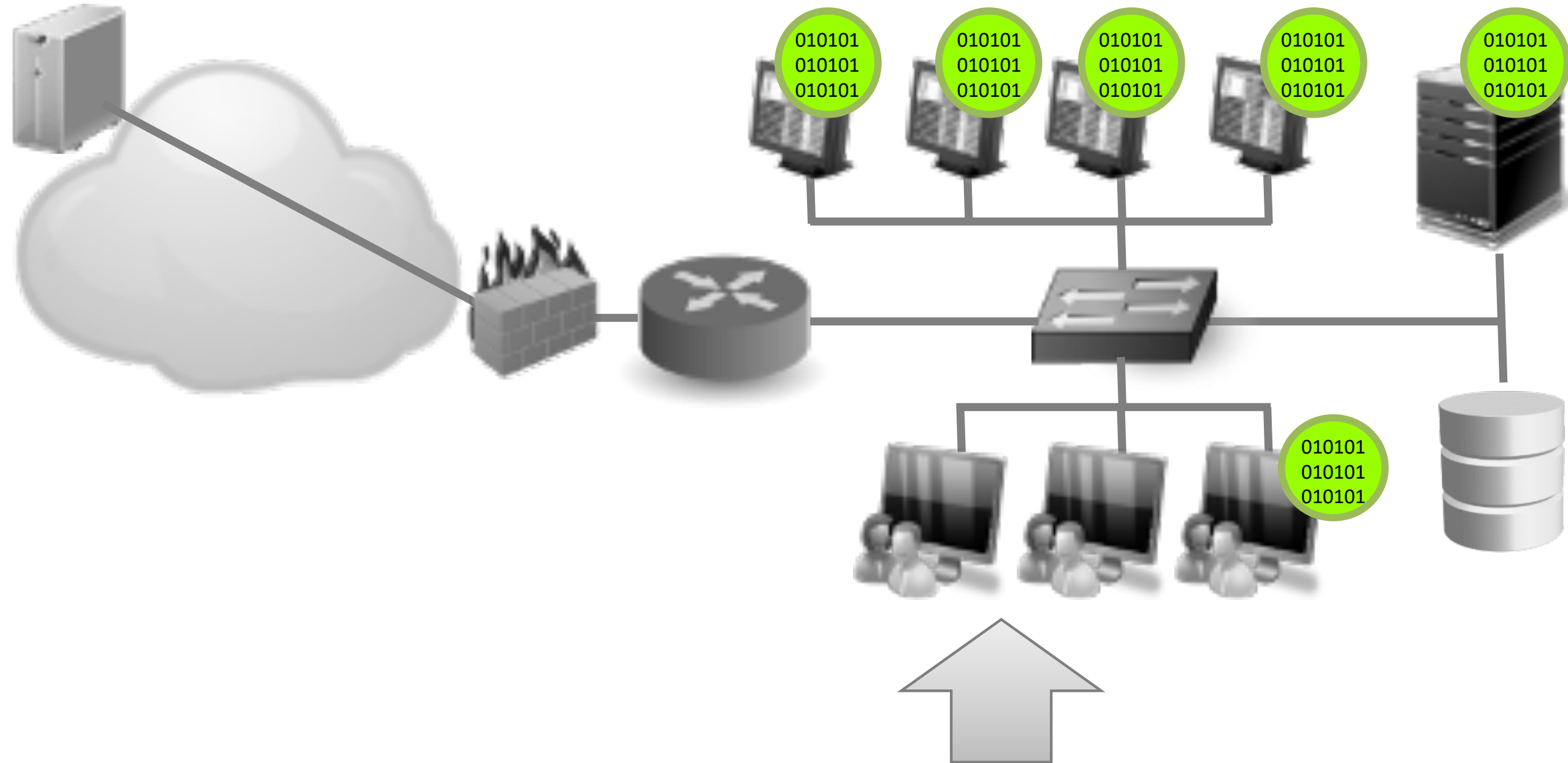
Controls: Data at Rest



② Endpoint monitoring and protection

- ✓ Hardened OS images for hosts
- ✓ Deploy application whitelisting tools and integrate with software inventory management tools
- ✓ Deploy local security controls for malware defence
 - Host IDS, antivirus, firewall
- ✓ Anti-exploitation tools for virtualisation and containerisation of applications e.g., DEP, EMET
- ✓ Detect unusual access patterns at host (e.g., network enumeration, credential brute-forcing, privilege escalation)
- ✓ Deploy file-integrity checking tools
 - Alert on alterations to specific files, permissions changes on files and directories
 - Alert on new files in system areas

Controls: Data in Use



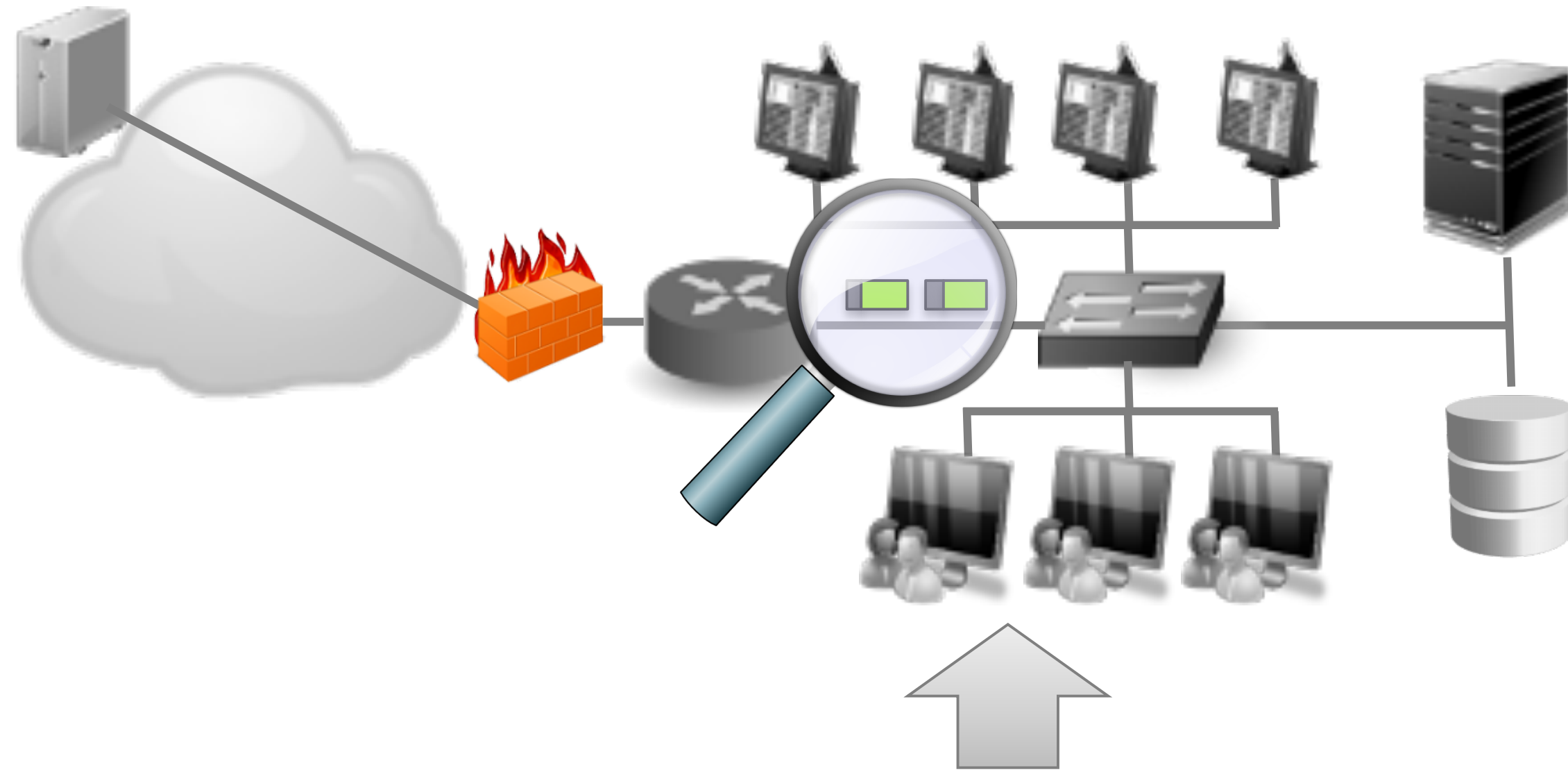
④ Protecting Data (in Use)

- ✓ System hardening and secure configuration for host
- ✓ End-to-end encryption

③ Sensitive Data (in Use) Discovery

- ✓ Assess where data in memory is vulnerable to RAM-parsing malware
- ✓ Does data need to be in clear text in memory?

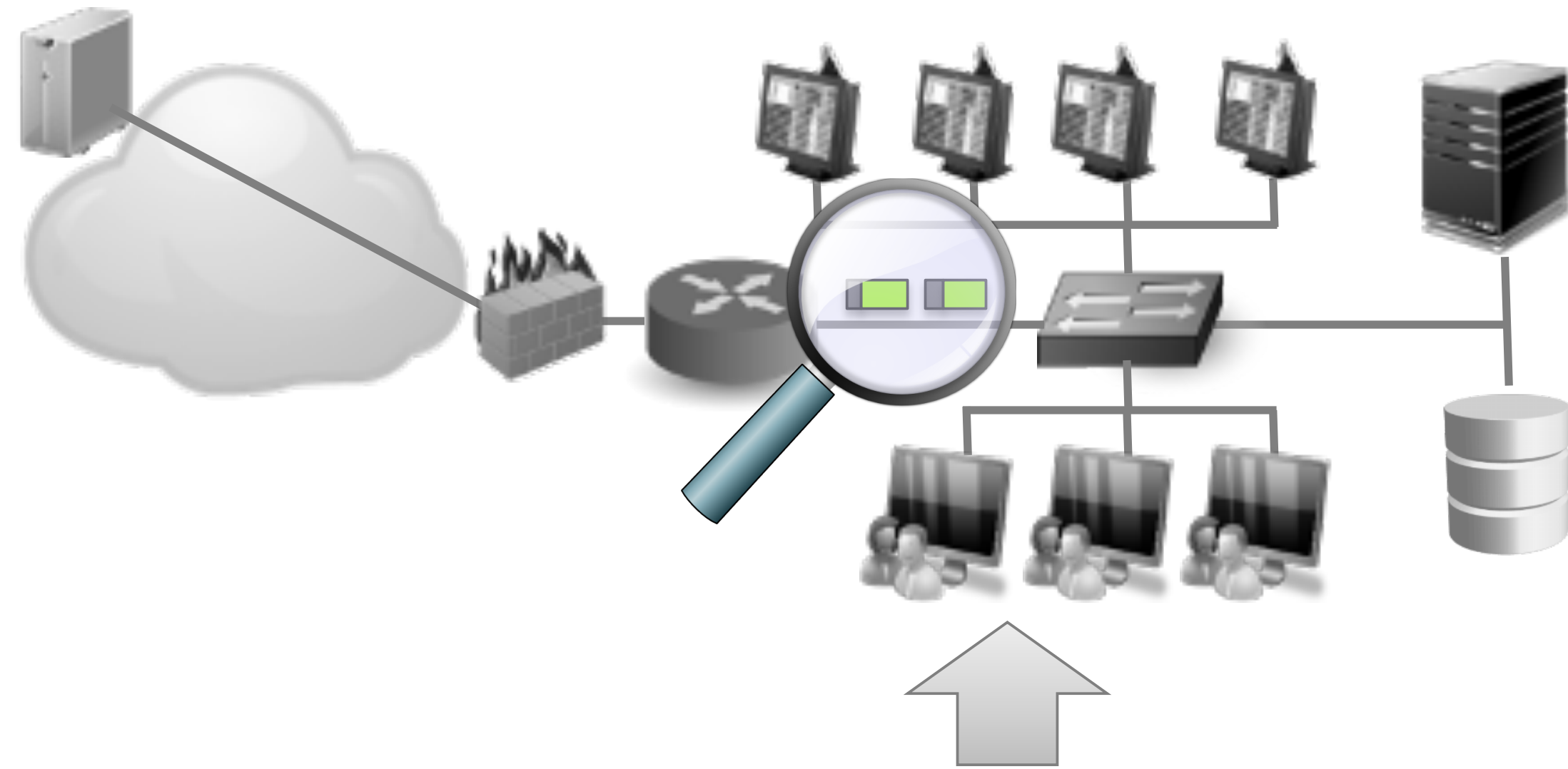
Controls: Data in Motion



⑤ Network Monitoring

- ✓ Logging and log analysis: web proxy, DNS, hosts, databases
 - Alert on high character entropy on domain name in DNS request
 - Alert on HTTP requests to unknown domains
- ✓ Access Control List at web proxy to block access to blacklisted domains
- ✓ Deploy Deep Packet Inspection tools
 - E.g. nDPI, openDPI, PACE, NBAR, L7Filter, Libprotoident
 - Select tools that provide coverage of most channels including cloud-storage uploads
 - Steganalysis modules integration if possible
 - Caveat: requires significant amount of processing power and can be beaten by encryption or signature-changes in applications/protocols

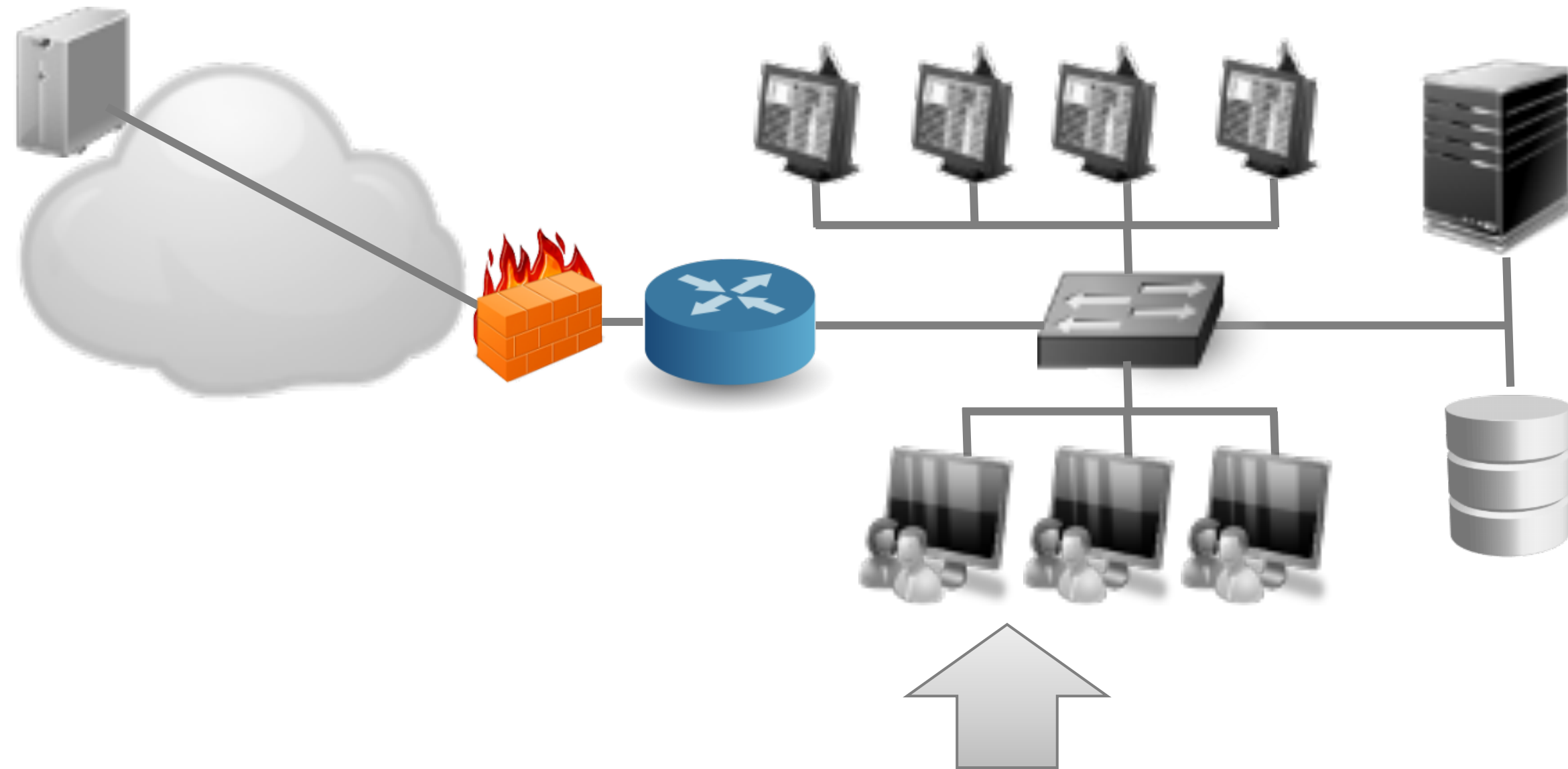
Controls: Data in Motion



⑥ Network Flow Monitoring

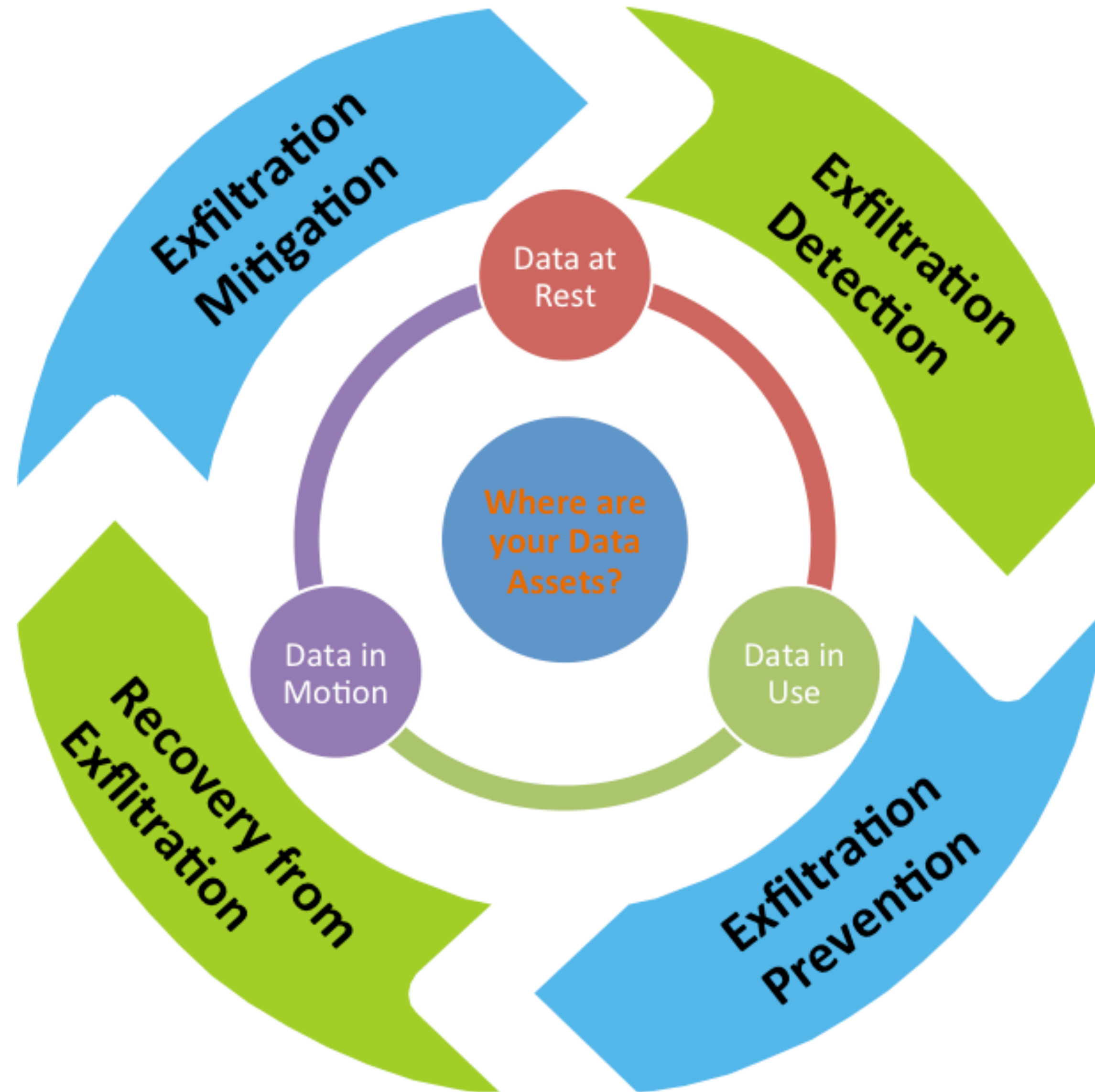
- ✓ Deploy Netflow analysers and DLP tools to monitor and control data flow within network
 - Detect network anomalies
 - Detect malware challenge/response communication patterns
 - Identify suspected pivot points in network
- ✓ Configure alerts based on
 - repeating byte count patterns above threshold and on periodicity
 - Suspect Data Loss
- ✓ Open-source Netflow analyser tools: Ntop, FlowTools, FlowScan, nfSen/nfdump, BPFT

Crosscutting Controls



- ⑦ Inspect high risk exfiltration channels: HTTP, HTTPS, SMTP, FTP, IM
- ✓ Deploy channel proxy (e.g. Squid web proxy, email filters) with DLP modules for content analysis, file-hash, regex strings, signatures matching
 - ✓ Use tools to generate file signatures (e.g. CERT's Tagger tool)
 - ✓ Use tools like Squid + ClamAV to match signatures and block file attachments
 - ✓ Consider proxy rules such as blocking file attachments to webmail
 - ✓ Reverse SSL proxy to analyse contents of SSL/TLS transactions

Where are your Data Assets?



Further Reading

Rashid et al. Detecting and Preventing Data Exfiltration. *CPNI iData Programme Report* (posted in Google Drive).

Faheem Ullah, Matthew Edwards, Rajiv Ramdhany, Ruzanna Chitchyan, Muhammad Ali Babar, Awais Rashid: *Data exfiltration: A review of external attack vectors and countermeasures*. *J. Netw. Comput. Appl.* 101: 18-54 (2018). Available: <https://doi.org/10.1016/j.jnca.2017.10.016>